XITA Direct-BLS Comprehensive security delta re-audit v3.3.0

Audit ID: XITA-DBLS-2026-11-06-v3.3.0. **Date:** 6 November 2026. **Reviewer:** OpenAI GPT-6 Astra Pro, AI-assisted security assessment. Solana is completely excluded.

1. Executive opinion

The current unique-cause register contains **0 Critical, 0 High, 11 Medium, 15 Low, 3 Informational and 10 resolved causes: 39 entries in total**. Zero Critical/High means none was demonstrated within this review's scope and evidence, not a guarantee of absence. The separate v3.5.0 legacy consensus cause is not mixed into the XITA count.

Three prior causes are newly verified resolved: F-06 restricted-role dependencies, F-32 unverified request-storage retention, and F-33 the asynchronous post-timeout payout effect. F-04 is downgraded from Medium to Low because retry/failure isolation improved, but is not closed. F-20 remains Medium with a narrower persistence residual. Four new Creator causes are added: one Medium availability defect, two Low recovery/provenance defects and one Informational presentation inconsistency. Historical occurrences are reconciled without duplication.

The source opinion remains CONDITIONAL GO for restricted self-funded core transfers. Unrestricted unattended sponsorship is not approved because bounded all-chain servicing and controlled paid-obligation outcomes remain incomplete, not because the now-fixed timeout/role causes are still open. Public unattended Creator intake has a separately demonstrated queue-isolation availability defect. Correctly deployed token ownership and on-chain mint controls were not shown compromised. The node companion has positive targeted possession/fork evidence, subject to its stated limits.

2. Baselines, method and exclusions

The audit freezes product revisions before review. Interchain adds 151 commits/333 changed paths to the preceding source baseline; 117 paths are audit publication and 216 are non-audit changes. Node adds nine commits/65 paths. The API's earlier 300-file page was not treated as a complete inventory; full local Git comparison supplies the record. Unchanged dependencies reachable from changed trust boundaries are included where relevant. Documentation-only release updates do not become new tested product code.

Source: xgr-interchain baseline 5cfc095d0f02271427832ee6bbb268322f38ae2d; target 33a4e37cf48c509b83c67d8007c246ff2838c606

Source: xgr-node baseline 51d92f1ab9b1ba52f62e2ff903c6ff0a7c2f5671; target a84c82737dc3ca195192a96498eab0e170f8bb5a

The source-first Phase A was sealed before detailed historical reconciliation, with original SHA-256 24618adefa6ac2955c45de21a3121e49fd84cadb333b6d8c6613ff0b2779c320. Prior finding summaries were already present in the conversation, so the process was not genuinely blind. This is an AI-assisted review, not an independent external audit firm's certificate or a claim of independence from AI-assisted prior development. The public Phase A derivative intentionally differs from the protected master and identifies that provenance.

No Solana branch, program, address format, route or deployment is evaluated. No product fixes, Mainnet transactions, payouts, deployments, configuration changes or service restarts are performed. Writes are limited to audit documentation, isolated evidence tooling and publication. New unresolved executable reproductions remain protected; public evidence contains only publication-safe findings and previously public regression/observation material.

3. Reviewed trust boundaries and positive controls

The review traces source operation/asset/route/fee evidence into Direct-BLS authorization, current validator-set binding, destination verification and native/synthetic/collateral accounting. Replay across message, route, destination and ISM is covered by the contract tests and reviewed unchanged authorization dependencies. The separate staking possession change does not replace Registry V3 membership proof requirements.

BSC uses the runtime finalized policy and Optimism the configured safe policy, with receipt-pinned registry/source activation identities and no fallback to latest merely to obtain progress. Admin status promotion is separately assessed under F-22; it must not be conflated with the stronger runtime signing policy. Shared external RPC infrastructure remains a trust dependency, not a cryptographic light-client proof.

Sponsorship review covers quote/intent reservations, immutable liabilities, restricted database roles, prepared signed transaction identity, timeout/read/effect separation, two-hop promise servicing, provisional/final receipt state and monitoring. Creator review covers public registration/email confirmation, private storage/retention, PNG normalization, queue/nonce/budget ownership, shared sponsor-wallet guards, child-token verification, feature/owner authority and the separation between token creation and Interchain route approval.

Node review separately follows proof domain/nonce binding, canonical manifest decoding and exact coverage, staking storage/runtime migration, parent-state signing authority, fallback/cached selection, historical parent seals, join CLI and isolated fresh synchronization. Complete inventories and source-reference matrices are supplied; they are not a formal coverage percentage or exhaustive symbolic proof.

4. Execution, observations and interpretation

The fresh broad XITA run executes 173 test files: 165 pass and eight fail. All eight are triaged individually rather than suppressed. The fresh Solidity run passes 111 tests across 17 suites, including Creator authority/caps, Direct-BLS/replay, native claim backing and two-hop accounting. The node validation passes 19 selected package groups, reproducible artifact/layout checks, a full build and a four-validator fork/restart/fresh-import test. JSON-RPC, runtime and possession packages also pass three repeated runs.

Actual restricted PostgreSQL role tests establish the narrow F-06 repair while debt mutation stays denied. Independent local Creator negatives use real application code with controlled RPC/mail/time effects and zero real broadcasts. A positive ordinary path is retained so an invalid fixture is not mistaken for evidence of a general outage. Exact logs, environments, result matrices and protected fixture identities are enumerated in verification.md.

Read-only production evidence covers 101 retained receipt records at two configured endpoints each: 114 verified observations, 88 unavailable from the CI network, and zero demonstrated mismatches. BSC receipt/runtime verification was unavailable; a positive finalized head is not substituted for that missing evidence. Both XGR endpoints agree on the reviewed staking runtime, migration marker and sampled block/state identities around the already activated fork. Missing host/role/journal evidence remains a targeted assurance question, not an invented vulnerability or blanket NO-GO reason.

5. Operating decisions

Self-funded Direct-BLS core transfers

CONDITIONAL GO. No new principal-authorization, token-backing or message-forgery regression was demonstrated in the reviewed delta. Retain authenticated route/asset/ISM/current-set bindings, the configured native finality policy, supported native-recipient restrictions and supervised recovery/backlog controls. Correlated RPC witnesses remain a stated trust dependency. This is not approval for arbitrary code-bearing native recipients or unlimited load.

Regular unrestricted unattended optional sponsorship

NO-GO. F-06 and F-33 are now verified source closures; they are no longer the blockers. F-08 and F-19 still prevent a reliable all-chain autonomous servicing and controlled paid-obligation outcome claim. Immutable liabilities are preserved, but preservation alone is not fulfillment. This decision is based on source behavior, not missing per-host attestations.

Staffed, bounded sponsorship and recovery

CONDITIONAL GO. Requires an explicitly approved operator-owned outcome/escalation process for outstanding obligations, effective restricted-role migrations, fair/backlog monitoring, exact transaction/nonce preservation and a separately authorized operating plan. No such new policy acceptance or production enablement is supplied by this audit. Never delete an uncertain obligation or re-sign it solely to recover availability.

Public unattended Token Creator intake

NO-GO for an unattended availability claim. F-36 is a freshly reproduced application-to-worker failure-isolation defect. An admitted unprocessable item can prevent healthy queued work from progressing. Correct validation and per-item failure isolation before claiming autonomous public intake. Existing correctly deployed tokens are not invalidated, and unauthorized token ownership or minting was not demonstrated.

Supervised Creator operation

CONDITIONAL GO. Only under an explicit operator-controlled intake/recovery procedure that avoids the demonstrated blocking condition and preserves every uncertain deployment identity. This does not authorize deletion of unresolved journal records. Address F-37/F-38 recovery/provenance limitations and F-39 misleading presentation.

XGR node v3.5.0 possession delta

CONDITIONAL GO within the reviewed delta. The known rogue-key admission cause is verified remediated on the frozen source. Fresh build/package/fork/import tests and read-only runtime/activation observations are positive. No additional Critical or High defect was demonstrated. Preserve the already activated canonical fork/manifest and normal quorum rules; do not repeat migration, restake or roll back to a pre-fix binary. This is not a whole-node audit or an attestation of every installed executable.

6. Complete current finding register

Severity and disposition are distinct. RESOLVED identifies a removed original cause; PARTIALLY_MITIGATED retains the residual. ACCEPTED_RISK carries only the prior explicitly bounded acceptance. Source fixes and actual installation are not silently equated.

F-01 - Native system-transaction accounting and proposal validation

Current: RESOLVED / VERIFIED / RESOLVED. **Previous:** RESOLVED / VERIFIED / RESOLVED.

Original cause / boundary. Native StateTx execution could receive ordinary refund/fee credits without a matching upfront debit. The proposer-validation boundary did not restrict admissible system transactions tightly enough or require deterministic header base-fee equality. The original prerequisite was proposer-controlled block content, not an ordinary bridge UI action.

Current assessment. The securityAccounting rejection, epoch-marker and parent-derived base-fee controls remain in place. The v3.5.0 executor/IBFT changes add the possession migration hook without removing these original accounting boundaries. Unchanged enforcement dependencies and the changed integration points were checked against the previous baseline.

Evidence. Fresh source comparison; fresh state and IBFT package execution in E-02; prior independent accounting/rejection evidence retained as inherited, not represented as a newly rerun custom suite.

Limits. The present fork test exercises possession migration, not every historical native exploit fixture or a Byzantine live-network proposal. RPC version strings do not establish each host binary hash.

Smallest appropriate action. Retain the original securityAccounting configuration and regression controls. No corrective product change is required for the original resolved cause.

Source: xgr-node @ a84c82737dc3 / state/executor.go.

Source: xgr-node @ a84c82737dc3 / consensus/ibft/security_accounting.go.

Source: xgr-node @ a84c82737dc3 / consensus/ibft/verifier.go.

Source: xgr-node @ a84c82737dc3 / consensus/ibft/ibft.go.

Source: xgr-node @ a84c82737dc3 / blockchain/security_accounting.go.

F-02 - Transaction-original storage and refund accounting

Current: RESOLVED / VERIFIED / RESOLVED. **Previous:** RESOLVED / VERIFIED / RESOLVED.

Original cause / boundary. The original storage snapshot could retain a previous transaction’s original-slot state inside one block. Refund subtraction could wrap an unsigned counter. This changed transaction gas/refund accounting; the historic refund cap limited the demonstrated effect and did not establish arbitrary minting.

Current assessment. Transaction-original storage and refund-accounting corrections remain present. State transaction/storage dependencies are unchanged; the changed executor integration was inspected for interference from the possession hook. Fresh state package tests pass.

Evidence. Fresh blob comparison and source review; E-02 state package result; original differential/rejection traces remain inherited evidence.

Limits. A passing package run is not a new exhaustive independent refund matrix. No regression of the originally resolved cause was demonstrated.

Smallest appropriate action. Preserve original-value tracking, refund invariants and rejection tests; keep migration writes outside ordinary transaction refund semantics.

Source: xgr-node @ a84c82737dc3 / state/executor.go.

Source: xgr-node @ a84c82737dc3 / state/txn.go.

Source: xgr-node @ a84c82737dc3 / state/state.go.

F-03 - Expensive gossip work lacks complete admission bounds

Current: Medium / OPEN. **Previous:** Medium / OPEN.

Original cause / boundary. Peer checkpoint votes and quorum hints can trigger full source verification before sufficiently cheap member/signature admission. Gossip delivery starts a goroutine for each message. Governance proposal admission lacks a global count/disk limit and an upper bound on accepted future expiry.

Current assessment. The general gossip/governance admission paths still allow substantial work before complete bounded admission and deduplication. New JSON-RPC request-storage limits do not impose an equivalent global budget on every peer-originated verification path. The original availability boundary remains relevant.

Evidence. Fresh inspection of unchanged network/worker/governance dependencies and changed checkpoint integration; E-02/E-04 validate ordinary runtime behavior, not a full adversarial saturation campaign.

Limits. No production consensus outage or principal compromise was induced. This is distinct from the now-resolved unverified per-message storage cause F-32.

Smallest appropriate action. Add cheap authenticated admission/deduplication and bounded global/per-peer work before expensive remote verification, preserving complete evidence checks before signing.

Source: xgr-node @ a84c82737dc3 / network/gossip.go.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/worker.go.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/iln_checkpoint.go.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/iln_quorum_request.go.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/governance.go.

F-04 - Shared observer retry fairness and failure isolation

Current: Low / PARTIALLY_MITIGATED. **Previous:** Medium / OPEN.

Original cause / boundary. The earlier shared-cursor defect let one failed operation stall sibling routes. Durable retry storage mitigated that original failure, but retry service always starts from the same route ordering and consumes a fixed source-wide budget; corrupt or full retry storage can still affect the source group.

Current assessment. Rotating bounded route retries remove the fixed-prefix starvation condition, and corrupt records no longer necessarily abort healthy siblings. Fresh repeated runtime tests support this improvement. Capacity-pressure and filesystem failure paths can still hold shared observer progress, so the finding is downgraded rather than closed.

Evidence. Fresh review of iln_observer_retry.go, checkpoint/storage integration and their tests; E-02 and three repeated runtime runs in E-04.

Limits. The narrower residual needs route-capacity pressure or persistent local I/O problems. Time-based rotation is not a proof of arbitrary-timing fairness or unlimited throughput. A durable fair-service SLA was not established.

Smallest appropriate action. Isolate capacity/I/O failures per route, retain evidence on quarantine and measure oldest work; add capacity-saturation and restart fairness tests before claiming autonomous progress under overload.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/iln_observer_retry.go.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/iln_observer_worker.go.

F-05 - External source witnesses retain correlated-provider trust

Current: Medium / OPEN. **Previous:** Medium / OPEN.

Original cause / boundary. External-source signing historically depended on a provider view that honest BLS validators could share. Requiring two labelled operators removed the single-counted-witness failure mode but left correlated or colluding providers and their upstreams inside the trust boundary.

Current assessment. Complete source evidence is compared across distinct operator-labelled RPC witnesses, but labels and URLs do not establish independent physical upstreams. BSC and Optimism extend the same trust model. Native safe/finalized checks and fail-closed message binding remain positive controls; two correlated or colluding counted witnesses remain the relevant trust prerequisite.

Evidence. Fresh witness/finality/configuration source review; E-02 finality tests; E-05 live read-only observations. The unchanged quorum comparison implementation is recorded in the source matrix.

Limits. No false live quorum was constructed. HTTP 403/429 observations are reachability limits, not evidence of collusion or invalid chain state. Safe L2 evidence is not represented as final L1 settlement.

Smallest appropriate action. Document actual upstream control, diversify witnesses and monitor disagreement. Reassess on correlated-provider discovery; do not weaken finality or invent new operator acceptance.

Source: xgr-node @ a84c82737dc3 / interchain/evm/rpc_evidence_quorum.go.

Source: xgr-node @ a84c82737dc3 / interchain/config.go.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/iln_direct_signing.go.

F-06 - Restricted-role reads and readiness omit new quote/monitor dependencies

Current: RESOLVED / VERIFIED / RESOLVED. **Previous:** Medium / OPEN.

Original cause / boundary. Missing SELECT used by aggregate quote query while readiness falsely passes; prior operations/resolutions repair was verified.

Current assessment. The supported quote writer now receives the required narrow intent SELECT permission; the status reader receives the overtaken-obligation read dependency. Readiness checks include the new dependency. An isolated PostgreSQL test executed the real monitor queries and exact production readiness SQL under restricted roles; all required checks passed after the documented migration.

Evidence. E-03 restricted-roles.json/log: missing intent read detected before repair, all nine readiness checks true after repair, joined reads succeed, UPDATE/DELETE on immutable debt tables denied, unrelated role promotion rejected.

Limits. This verifies source/schema/role behavior in disposable PostgreSQL, not installation of the migration on every production database or a new paid quote transaction.

Smallest appropriate action. Apply/verify the documented narrow migration during normal authorized operations and retain role-level regression tests. Do not use superuser or grant debt mutation as a workaround.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/tax-evidence.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/indexer/sql/011_quote_writer_runtime_grants.sql.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/server.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/indexer/sql/014_sponsor_overtaken_obligations.sql.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/sponsor-obligation-audit.mjs.

F-07 - Sponsor reservation can strand the sender nonce after interruption

Current: RESOLVED / VERIFIED / RESOLVED. **Previous:** RESOLVED / VERIFIED / RESOLVED.

Original cause / boundary. The reservation committed before a signed transaction or durable hash existed. Restart only selected submitted rows with a hash, so a crash left an unrecoverable reserved nonce blocking later grants.

Current assessment. Prepared exact signed transaction bytes, hash and nonce ownership remain durable before broadcast. The new Creator shared-wallet guard does not authorize replacement signing of uncertain sponsorship rows. Fresh sponsor tests preserve the original identity/recovery controls.

Evidence. Fresh sponsor source review and E-01 managed-relay/real-schema tests; exact-byte recovery remains separate from F-33 effect fencing.

Limits. No historical production orphan was resolved by this audit. Preserving a row is not proof that every old obligation has completed.

Smallest appropriate action. Keep original transaction identity and nonce ownership through uncertainty. Investigate pre-upgrade rows under controlled reconciliation, never by blind re-signing.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/gas-sponsor.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/indexer/sql/013_sponsor_prepared_tx.sql.

Source: xgr-interchain @ 33a4e37cf48c / services/indexer/sql/004_sponsor_grants.sql.

F-08 - One grant RPC failure can block all-chain sponsorship

Current: Medium / PARTIALLY_MITIGATED. **Previous:** Medium / PARTIALLY_MITIGATED.

Original cause / boundary. v3.0 had escaping submitted-grant errors and oldest-only windows; v3.1 fixed that helper but left earlier serial expiry and reserve reads able to block all later stages.

Current assessment. The repaired recovery helper bounds raced read work, but the full fresh-candidate sweep still contains serial provider-dependent preflight paths that can delay service to otherwise healthy chains. The narrower F-33 fix does not establish fair, bounded all-chain servicing.

Evidence. Fresh runSweep/preflight and recovery call-graph review; E-01 timeout controls pass for their actual helper scope.

Limits. No live outage was generated. An outer timeout around an effectful callback would reintroduce the resolved late-broadcast problem and is not an acceptable fix.

Smallest appropriate action. Bound read-only preflight end-to-end and schedule independent chains fairly. Test a deliberately stalled provider while healthy chains progress, without cancelling or replacing uncertain sends.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/gas-sponsor.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/sponsor-event-listener.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/xita-gas-sponsor.service.example.

F-09 - Mailbox completion can conceal a pending native-principal claim

Current: Medium / OPEN. **Previous:** Medium / OPEN.

Original cause / boundary. Authenticated native delivery can fail to pay recipient code within the router's 30,000-gas allowance. The router reserves a backed pending balance and returns successfully, so Mailbox delivery does not necessarily mean native principal reached the beneficiary. The presentation layer equates these states.

Current assessment. The native router preserves backed deferred claims and beneficiary-only withdrawal when direct native delivery fails. Mailbox completion can nevertheless still be presented as fully received principal, and arbitrary recipient contracts may lack a usable claim path. UI changes in this delta do not eliminate the original distinction.

Evidence. Fresh router/presentation review and E-06 native fallback tests covering reserved backing, accumulation, failed withdrawals and beneficiary authorization.

Limits. No unbacked claim or unauthorized withdrawal was demonstrated. The issue is recipient support and truthful completion, not a claim that every completed message loses funds.

Smallest appropriate action. Retain the restricted code-free or separately verified claim-capable recipient policy; expose deferred native principal and the existing beneficiary-authorized recovery path explicitly.

Source: xgr-interchain @ 33a4e37cf48c / contracts/XETAGuardedNativeWarpRouter.sol.

Source: xgr-interchain @ 33a4e37cf48c / services/indexer/transfer-index-store.mjs.

Source: xgr-interchain @ 33a4e37cf48c / apps/web/transfer-status-flow.js.

Source: xgr-interchain @ 33a4e37cf48c / apps/web/transfer-token-journey.js.

F-10 - Authorized ownership transfer can collapse service/admin separation

Current: Low / OPEN. **Previous:** Low / OPEN.

Original cause / boundary. The gateway constructor and service-wallet setter enforce different service and recovery-admin addresses, while inherited two-step ownership nomination/acceptance do not enforce the same invariant, including the pending-owner rotation order.

Current assessment. Authorized ownership/service-wallet transitions can still converge the intended independent roles. The relevant gateway ownership implementation is unchanged. This is an authorized-role separation weakness, not an arbitrary external takeover.

Evidence. Fresh unchanged-source comparison and ownership/fee-wallet tests within E-06.

Limits. The triggering actor already holds the relevant administrative authority. Ordinary token holders were not shown to gain it.

Smallest appropriate action. Check current and pending ownership during rotation. A future contract revision should enforce role inequality across nomination, acceptance and service-wallet changes in either order.

Source: xgr-interchain @ 33a4e37cf48c / contracts/XITAExecutionGateway.sol.

Source: xgr-interchain @ 33a4e37cf48c / vendor/package.json.

F-11 - Membership authorizations omit the exact registry deployment

Current: Medium / ACCEPTED_RISK. **Previous:** Medium / ACCEPTED_RISK.

Original cause / boundary. Membership payloads bind chain/domain, expected set, expiry, action and keys but omit the exact registry deployment address. Equivalent simultaneously active deployments can therefore accept the same valid membership authorization.

Current assessment. Membership signatures retain the prior deployment-unbound domain under the documented single-active-registry model. Direct transfer signatures separately bind registry/ISM identities. The existing bounded risk acceptance is retained; adding chains is not an implicit acceptance of overlapping registry migrations.

Evidence. Fresh Registry V3/domain review and receipt-pinned chain configuration; E-06 membership and Direct-BLS replay tests.

Limits. The audit did not prove absence of every unlisted alternative deployment, nor authorize simultaneous equivalent active registries. The pre-existing acceptance is not expanded.

Smallest appropriate action. Maintain a single active receipt-pinned registry per stated domain. Reopen the design before overlapping migrations and use an explicitly versioned address-bound membership domain if the invariant changes.

Source: xgr-interchain @ 33a4e37cf48c / contracts/XGRInterchainValidatorRegistryV3.sol.

Source: xgr-interchain @ 33a4e37cf48c / contracts/XITADirectProtocol.sol.

Source: xgr-node @ a84c82737dc3 / interchain/config.go.

F-12 - Minimum validator committee size remains an operating rule

Current: Low / OPEN. **Previous:** Low / OPEN.

Original cause / boundary. Bootstrap requires a nonempty committee rather than a minimum of three, and authorized membership removal stops only at one remaining member. The correct ceil(2n/3) threshold consequently becomes one signature for a one-member set.

Current assessment. A minimum independently operated committee size remains an operating policy rather than a hard on-chain minimum. Correct threshold calculation does not establish independence or a minimum committee of three.

Evidence. Fresh registry/quorum source review and E-06 current-set membership controls.

Limits. Consensus migration's five proven keys must not be confused with five independent Interchain operators. Active bridge committee independence was not newly attested.

Smallest appropriate action. Monitor the documented operating minimum and rotation continuity. Any hard minimum or altered governance rule needs a separately authorized design and migration decision.

Source: xgr-interchain @ 33a4e37cf48c / contracts/XGRInterchainValidatorRegistryV3.sol.

F-13 - Wallet proof calldata is not fully bound to selected intent

Current: Low / OPEN. **Previous:** Low / OPEN.

Original cause / boundary. The browser validates metadata, destination, selector and zero native value but does not decode process message bytes and bind their hash to the selected source message.

Current assessment. Wallet proof submission retains basic selector/target/value checks without fully decoding and binding the submitted valid message to the user's selected intent. Contract-side authorization still prevents arbitrary forged value delivery; a substituted independently valid operation remains a wallet-intent/gas-spend concern.

Evidence. Fresh unchanged wallet submission-path review and relevant E-01 wallet regression runs.

Limits. No message forgery or principal redirection through a bad signature was demonstrated. Existing proofs and source records remain required.

Smallest appropriate action. Decode the process arguments and compare the complete authenticated message identity with the selected transfer before requesting wallet submission; test substituted valid messages.

Source: xgr-interchain @ 33a4e37cf48c / apps/web/transfer-actions.js.

Source: xgr-interchain @ 33a4e37cf48c / services/indexer/transfer-recovery.mjs.

Source: xgr-interchain @ 33a4e37cf48c / runtime/native-relayer/xita-direct-codec.mjs.

F-14 - Regression fixtures and CI discovery drift from the current product

Current: Low / OPEN. **Previous:** Low / OPEN.

Original cause / boundary. Some negative tests assume obsolete behavior and CI uses manually enumerated test lists, omitting existing and newly added suites.

Current assessment. The broad isolated discovery run executes 173 test files, of which eight fail. Triage identifies stale catalog/address/copy assumptions, a configured-mail fixture dependency and a historical deployment-component alias assertion; none alone demonstrates a new principal vulnerability. Manually enumerated normal CI can still be green while these regressions fail.

Evidence. E-01 all 173 logs and test-failure-triage.json; E-06 is a separate 111-test Solidity result, not a substitute for the JavaScript failures.

Limits. Tests were not edited to obtain green results. The audit distinguishes test-file exit status from individual assertions and does not add unrelated suite totals as unique exploit counts.

Smallest appropriate action. Update fixtures narrowly against authenticated current inventory/intentional behavior, retain negative security assertions and discover the full supported test set in CI. Preserve strict receipt/runtime validation when recognizing component aliases.

Source: xgr-interchain @ 33a4e37cf48c / .github/workflows/validate.yml.

Source: xgr-interchain @ 33a4e37cf48c / services/indexer/rpc-read.test.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/gas-sponsor.test.mjs.

F-15 - Production sponsorship and installation readiness remain unproven

Current: Informational / OPEN. **Previous:** Informational / OPEN.

Original cause / boundary. The old read-only observation reported sponsoring enabled but unavailable; installed service, role, journal and build identity were not demonstrated. It was not an identified source-level exploitation path.

Current assessment. Positive live contract and activation observations were obtained, but exact installed service revisions, effective production database-role migration, aged obligation outcomes and representative existing paid-operation evidence remain installation-assurance tasks. They are not fabricated source vulnerabilities.

Evidence. E-03 actual restricted-role test; E-05 202 endpoint observations and node runtime checks; scope-specific limitations in verification.md.

Limits. No new Mainnet transfer or payout was requested. BSC receipt reads were unavailable from the CI vantage point. Separate node release metadata and observed client toolchain strings differ, so per-host binary identity is not established.

Smallest appropriate action. When a concrete installed-service approval depends on it, request existing sanitized revision/role/journal-age/outcome records and installed binary hashes. Do not turn missing evidence alone into a blanket NO-GO.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/server.mjs.

F-16 - Expiry-release evidence trusts one RPC without a canonical reread

Current: RESOLVED / VERIFIED / RESOLVED. **Previous:** RESOLVED / VERIFIED / RESOLVED.

Original cause / boundary. One finalized/committed head plus a number-tagged nonce call could append expired-unused without independent agreement or a post-call hash reread, removing an actually owed liability from accounting.

Current assessment. Expiry release retains distinct witness comparison and canonical reread before a liability is released. The original single-view/no-reread cause remains absent. Changes elsewhere in quote lifecycle do not remove this control.

Evidence. Fresh source comparison/review and E-01 sponsor quote/finalized-resolution regressions; original entrypoint traces remain identified inherited evidence.

Limits. The audit did not perform a production expiry release. Provider physical independence remains F-05 rather than reopening the eliminated single-view implementation cause.

Smallest appropriate action. Retain independent witness configuration, immutable liability age and canonical reread tests; monitor unresolved backlog without dropping uncertain obligations.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/gas-sponsor.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/tax-evidence.mjs.

F-17 - Unpaid payer aliases still occupy finite sponsor admission capacity

Current: Medium / PARTIALLY_MITIGATED. **Previous:** Medium / PARTIALLY_MITIGATED.

Original cause / boundary. Public positive promises reserve budget without source payment; per-identity rate limits do not authenticate or bound distributed demand.

Current assessment. Per-wallet request limits and durable promises bound individual admission, but unpaid payer aliases can still occupy finite aggregate sponsor capacity. The delta does not provide Sybil-resistant capacity fairness. Existing obligations remain protected rather than silently expired for availability.

Evidence. Fresh quote admission/commitment source review and E-01 funding/admission tests.

Limits. No production capacity exhaustion was attempted. A per-address limit is not an identity limit, and the audit does not invent operator acceptance of an unlimited free-admission policy.

Smallest appropriate action. Adopt explicitly approved bounded admission and fairness controls while preserving every uncertain/paid liability. Measure saturation and recovery without adding an unrequested mandatory user signature.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/server.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/tax-evidence.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/sponsor-funding.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/gas-sponsor.mjs.

F-18 - Conservative daily-limit accounting can count a liability twice

Current: Low / OPEN. **Previous:** Low / OPEN.

Original cause / boundary. Outstanding commitments exclude only confirmed payouts while issued-today includes every recent grant status. The daily arithmetic adds these overlapping sets.

Current assessment. The conservative daily-spend plus outstanding-liability calculation can count some uncertain grants in overlapping sets. This can reject otherwise affordable new work, rather than proving treasury insolvency or duplicate payout.

Evidence. Fresh budget/funding arithmetic review and E-01 corresponding tests; the overlapping classification is not eliminated by the Creator's separate caps.

Limits. No exact production overcount amount was measured; live journals were not inspected.

Smallest appropriate action. Define mutually exclusive confirmed-spend and unsettled-obligation categories and test real-schema transitions/windows. Preserve uncertain obligations exactly once when changing arithmetic.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/tax-evidence.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/sponsor-funding.mjs.

F-19 - Paid grant lifecycle can remain unresolved after early delivery or shutdown

Current: Medium / PARTIALLY_MITIGATED. **Previous:** Medium / PARTIALLY_MITIGATED.

Original cause / boundary. Every stage requires the original parent undelivered; permissionless external completion can make an owed grant ineligible. The global disabled switch stops existing servicing as well as new promises.

Current assessment. Paid obligations are retained when external completion overtakes service, but recording an overtaken state is not a complete controlled-outcome process. Stopping new admission and servicing old debt are still insufficiently separated. This remains a blocker for an unrestricted unattended servicing claim even after F-33 is fixed.

Evidence. Fresh lifecycle, global-disable, overtaken-record and monitor review; E-01/E-03 establish durability and restricted reads, not fulfillment of every promise.

Limits. A staffed, explicitly approved outcome/escalation process may support a narrower operation. No such new policy was accepted on the operator's behalf. Automatic late gifts or debt deletion are not recommended.

Smallest appropriate action. Separate stop-new-admission from safe old-obligation reconciliation and implement operator-owned traceable outcomes with escalation. Preserve original nonce, transaction identity and liabilities throughout uncertainty.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/gas-sponsor.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/sponsor-obligation-audit.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/server.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/indexer/sql/014_sponsor_overtaken_obligations.sql.

F-20 - Pending recovery work can be removed before durable replacement

Current: Medium / PARTIALLY_MITIGATED. **Previous:** Medium / OPEN.

Original cause / boundary. Persisted votes can be removed when their route is temporarily missing or when a set changes, before successor signing succeeds. Old undelivered attestations can also be pruned after evidence is judged regenerable without persisting a replacement job.

Current assessment. Missing-route and undelivered-vote retention are improved, and ordinary expired-set handoff tests pass. A narrower source path remains in which a success return does not uniformly prove durable successor persistence before the original locator is removed. Therefore the original consume-before-success cause is not fully closed.

Evidence. Fresh caller/callee source proof across checkpoint, direct signing and durable storage; E-02/E-04 positive retention/handoff regressions. No new full end-to-end negative execution for this narrower branch is claimed.

Limits. This is a refinement of the existing finding, not a new duplicate finding. Public material omits a runnable unresolved trigger sequence. Known-hash recovery can mitigate availability but does not prove atomic handoff.

Smallest appropriate action. Make persistence/terminal-delivery status explicit, not inferred from a generic nil error. Delete original evidence only after authenticated completion or an atomic verified durable successor; test ineligible/failed persistence and restart cases.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/iln_checkpoint.go.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/iln_storage.go.

F-21 - Successful incomplete discovery responses can advance durable cursors

Current: Medium / OPEN. **Previous:** Medium / OPEN.

Original cause / boundary. A successful single-provider log query is treated as a complete discovery window. A well-formed response that omits real events can therefore advance durable operation or route-discovery cursors without creating retry records for the omitted entries.

Current assessment. A syntactically successful but incomplete discovery response can still advance a durable scan cursor. Full two-witness authorization of each discovered message does not itself prove completeness of the discovery list.

Evidence. Fresh scan/observer source review and unchanged-dependency comparison; E-02 ordinary discovery tests.

Limits. No unauthorized mint is implied: missing messages affect availability and discovery. No false live response was injected into production.

Smallest appropriate action. Use bounded overlapping reconciliation or independently checked completeness, retain known-hash recovery and alert on differing windows. Never weaken complete source verification to gain progress.

Source: xgr-node @ a84c82737dc3 / interchain/evm/iln_multi_gateway_scan.go.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/iln_observer_worker.go.

Source: xgr-node @ a84c82737dc3 / interchain/evm/iln_discovery.go.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/iln_discovery.go.

F-22 - Admin deployment evidence uses confirmation depth as finality

Current: Low / PARTIALLY_MITIGATED. **Previous:** Low / OPEN.

Original cause / boundary. verifyDeploymentReceipt obtains latest head/confirmations plus canonical numeric receipt block, but never requests adopted native safe/finalized head.

Current assessment. BSC admin reconciliation now recognizes finalized evidence and checks the canonical receipt block. The corresponding admin branch does not uniformly apply the safe policy requested for the L2 configurations, where confirmation-depth promotion remains. The Direct-BLS runtime's safe verification is a separate, stronger path.

Evidence. Fresh admin deployment-finality and BSC/OP configuration review; E-01 chain-finality tests and E-02 runtime finality tests; E-05 deployment observations.

Limits. No presently deployed contract mismatch or invalid validator signature was demonstrated. Read-only receipt identity checks are not a proof that every admin status path uses native finality.

Smallest appropriate action. Share the chain-native safe/finalized policy across admin reconciliation, pin receipt height/hash and canonical rereads, and keep provisional depth labels distinct from final approval.

Source: xgr-interchain @ 33a4e37cf48c / services/admin/deployment-ledger.mjs.

F-23 - Orphaned deployment locks require careful manual recovery

Current: Low / OPEN. **Previous:** Low / OPEN.

Original cause / boundary. Exclusive intents.lock file has no persisted owner lease; a killed process can leave it while finally cleanup never executes.

Current assessment. Exclusive deployment-intent locks can still survive an owner crash without a safe automatic owner/lease recovery protocol. Related operator locks require conservative recovery; age alone cannot prove that no transaction is in flight.

Evidence. Fresh admin intent/journal/locking source review and E-01 deployment recovery tests.

Limits. No lock was deleted or service restarted. This is bounded operational availability, not authority to discard an uncertain deployment or duplicate a nonce.

Smallest appropriate action. Provide explicit stale-owner verification and journal-preserving recovery. Preserve exact signed bytes, nonce and hash; never delete a lock solely because it is old.

Source: xgr-interchain @ 33a4e37cf48c / services/admin/deployment-intents.mjs.

F-24 - Verified paid-fee backfill still omits required event identity

Current: Low / OPEN. **Previous:** Low / OPEN.

Original cause / boundary. Backfill event lacks messageId/txHash required by storeVerifiedOperation provenance guard.

Current assessment. The paid-fee backfill still constructs an event without the complete message/source-transaction identity required by verified storage. Error handling can hold progress instead of producing the intended independently bound record. The unrelated indexed open-count change does not repair this path.

Evidence. Fresh backfillPaidFeeTax/storeVerifiedOperation call-site review and source comparison.

Limits. No fabricated verified record or stolen fee was demonstrated. The present audit does not claim a new actual-database backfill reproduction.

Smallest appropriate action. Pass the verified row's message ID and source transaction hash into the stored event and add a successful-store regression with real schema constraints.

Source: xgr-interchain @ 33a4e37cf48c / services/indexer/transfer-index-worker.mjs.

F-25 - Dense event windows lack adaptive progress

Current: Low / OPEN. **Previous:** Low / OPEN.

Original cause / boundary. Oversized bounded event windows fail before commit and are retried at the same cursor/window width instead of adaptively splitting.

Current assessment. Dense event windows still lack complete adaptive splitting/progress in the affected indexer path. Retrying the same overfull range can hold the cursor. Node-side bounded scans elsewhere do not close this distinct indexer cause.

Evidence. Fresh indexer window/cursor review and E-01 worker tests; unchanged relevant dependency paths recorded.

Limits. No dense Mainnet load was generated. The safety-preserving held cursor is preferable to silently skipping logs, but remains an availability limit.

Smallest appropriate action. Split bounded ranges adaptively and define a safe dense-single-block strategy. Advance only after complete canonical processing, retaining uncertainty rather than dropping records.

Source: xgr-interchain @ 33a4e37cf48c / services/indexer/transfer-index.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/indexer/transfer-index-worker.mjs.

F-26 - Unknown route rows can starve background delivery refresh

Current: RESOLVED / VERIFIED / RESOLVED. **Previous:** RESOLVED / VERIFIED / RESOLVED.

Original cause / boundary. Historical SQL applied LIMIT before filtering active source/route pairs, letting retired or cross-product rows crowd out valid delivery checks.

Current assessment. The corrected exact active source/route-pair selection precedes the batch limit, preventing unrelated unknown-route rows from occupying all selected work. The original query-level starvation cause remains removed.

Evidence. Fresh source comparison and E-01 exact-pair fairness regression; prior actual PostgreSQL negative/positive evidence remains inherited where not newly repeated.

Limits. Other provider waits and dense-window limits remain separately tracked. This closure is not an unlimited throughput guarantee.

Smallest appropriate action. Retain exact-pair filtering before LIMIT and the unrelated-row starvation regression.

Source: xgr-interchain @ 33a4e37cf48c / services/indexer/transfer-index-worker.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/indexer/sql/002_transfer_operations.sql.

F-27 - Published CLI version fields are empty despite valid embedded VCS data

Current: RESOLVED / VERIFIED / RESOLVED. **Previous:** RESOLVED / VERIFIED / RESOLVED.

Original cause / boundary. The former release workflow passed linker targets for an obsolete module path, leaving four product CLI version fields empty despite valid embedded Go VCS metadata.

Current assessment. Versioned build/linker identity controls remain corrected, and both observed XGR endpoints expose nonempty v3.5.0 client strings. The new release workflows preserve explicit revision/version checks.

Evidence. Fresh source/workflow review, E-02 build and E-05 client responses; canonical activation documentation is contextual evidence.

Limits. A nonempty version string is not a binary checksum. The observed Go toolchain string differs from the documented published asset toolchain; that traceability gap is explicitly retained in the companion review, without reopening the old empty-field cause.

Smallest appropriate action. Maintain nonempty version/commit checks and compare actual installed executable hashes with the intended release in ordinary operations.

Source: xgr-node @ a84c82737dc3 / .github/workflows/release.yml.

Source: xgr-node @ a84c82737dc3 / versioning/versioning.go.

Source: xgr-node @ a84c82737dc3 / command/version/version.go.

F-28 - Compiler advisory applicability remains an assurance gap

Current: Informational / OPEN. **Previous:** Informational / OPEN.

Original cause / boundary. The historical review left a project-specific compiler-equivalence/applicability question open for the Solidity 0.8.24 optimized via-IR artifacts. The old historical register included an advisory identifier; this audit does not adopt that identifier or its alleged affected-version range as a newly verified official fact.

Current assessment. The XITA compiler remains the recorded optimized via-IR Solidity 0.8.24 build. Fresh compilation/runtime provenance checks are positive, but they do not establish semantic equivalence or close a project-specific compiler applicability question. No historical unverified advisory identifier is adopted as a verified fact.

Evidence. Frozen foundry settings, E-06 build/import/constructor checks and E-05 runtime identity observations.

Limits. No project miscompilation, affected official advisory trigger or principal-loss path was demonstrated. Node staking's separately pinned Solidity 0.8.30 is a different artifact set.

Smallest appropriate action. Keep this an assurance task. Qualify a specific official issue and exact trigger/settings before asserting exposure; use targeted equivalence or corrected-build evidence rather than ordering redeployment from an unverified historical claim.

Source: xgr-interchain @ 33a4e37cf48c / foundry.toml.

Source: xgr-interchain @ 33a4e37cf48c / vendor/package.json.

F-29 - Membership and governance submission RPC remains unbounded

Current: Medium / OPEN. **Previous:** Medium / OPEN.

Original cause / boundary. Read-side witness RPC gained deadlines and worker-scope cancellation, but external membership and governance submissions construct a separate legacy transaction relayer. Its receipt timeout controls the interval between polls, not a bound on each preflight/send/receipt network call.

Current assessment. Membership/governance transaction submission retains unbounded remote wait paths outside the repaired sponsor helper. A slow external provider can prevent complete worker shutdown/progress. The possession migration does not repair these unchanged submission dependencies.

Evidence. Fresh worker/txrelayer/client call-graph inspection and exact-source comparison.

Limits. No forced production provider outage or node shutdown was performed. An outer timer alone cannot safely roll back a send whose outcome is unknown.

Smallest appropriate action. Carry bounded contexts through preflight, submission and receipt waits; test complete Worker.Close termination while preserving original transaction and nonce identity for uncertain sends.

Source: xgr-node @ a84c82737dc3 / interchain/evm/client.go.

Source: xgr-node @ a84c82737dc3 / interchain/evm/iln_governance_submit.go.

Source: xgr-node @ a84c82737dc3 / txrelayer/txrelayer.go.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/worker.go.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/governance_execute.go.

F-30 - Reconciliation refresh suppresses delayed-grant monitoring

Current: RESOLVED / VERIFIED / RESOLVED. **Previous:** RESOLVED / VERIFIED / RESOLVED.

Original cause / boundary. Retry scheduling refreshed updated_at while both delayed-grant and paid-commitment diagnostics used updated_at as the fifteen-minute age predicate, hiding old unresolved payouts after every retry.

Current assessment. Delayed-grant monitoring continues to use immutable creation age rather than mutable retry/heartbeat timestamps. The required status-reader privilege is now also repaired under F-06.

Evidence. Fresh source review, E-01 age regressions and E-03 actual restricted monitor query execution.

Limits. Actual production alert delivery and aged journal contents were not inspected. Those operational checks do not reopen the resolved age-predicate defect.

Smallest appropriate action. Retain immutable-age predicates and validate installed alert delivery using existing sanitized/synthetic monitoring evidence.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/sponsor-obligation-audit.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/gas-sponsor.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/sponsor-obligation-audit.pg.test.mjs.

F-31 - A failed destination receipt can retain transaction-submitted wording

Current: Low / OPEN. **Previous:** Low / OPEN.

Original cause / boundary. The retained first-delivery-pending stage outranks a failure notice after destination receipt failure; the UI renders submitted/do-not-resubmit wording despite failed result.

Current assessment. An explicit destination receipt failure can still coexist with a retained submitted/pending stage and misleading waiting wording. The delta's transfer-selection and copy changes do not consistently give the failure state precedence.

Evidence. Fresh transfer status/flow source review and E-01 existing presentation tests; no new wallet transaction was submitted.

Limits. The original source evidence should remain valid; a failed destination execution is not a reason to repeat the source lock. This is presentation/recovery guidance rather than message authorization.

Smallest appropriate action. Prioritize authenticated destination failure and offer only the appropriate destination retry while preserving source transaction/message identity.

Source: xgr-interchain @ 33a4e37cf48c / apps/web/app.js.

Source: xgr-interchain @ 33a4e37cf48c / apps/web/transfer-status-flow.js.

F-32 - Expired unverified route hints leave permanent per-message request storage

Current: RESOLVED / VERIFIED / RESOLVED. **Previous:** Medium / OPEN.

Original cause / boundary. An unauthenticated unknown-route quorum request allocates both a discovery hint and a per-message request directory before canonical route admission. Hint expiry/rejection removes only the hint, while background request cleanup traverses known routes only.

Current assessment. Unverified unknown-route request directories now have global admission/retention bounds and expiry cleanup. Verified votes and unfinished authenticated recovery evidence are not swept under the unverified-hint policy. The original permanent unbounded request-storage cause is removed.

Evidence. Fresh JSON-RPC/storage policy review; E-02 package tests and E-04 three repeated JSON-RPC/runtime runs including bound/expiry/churn controls.

Limits. This is not a general guarantee against every local disk exhaustion or expensive peer workload. Those broader resource boundaries remain F-03/F-04.

Smallest appropriate action. Retain bounded unverified admission and age-based cleanup tests, including restart behavior and preservation of authenticated work.

Source: xgr-node @ a84c82737dc3 / jsonrpc/xgr_iln_quorum.go.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/iln_quorum_request.go.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/iln_discovery.go.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/iln_storage.go.

F-33 - Timed-out sponsor recovery can initiate a late prepared payout

Current: RESOLVED / VERIFIED / RESOLVED. **Previous:** Medium / OPEN.

Original cause / boundary. Prepared-transaction recovery added a broadcast side effect inside a callback still raced as read-only. Promise.race times out its caller but never cancels the underlying callback. The destination-delivery gate precedes a potentially delayed nonce/transaction lookup; a late callback can initiate a send after the caller reported the work held and after independent destination completion.

Current assessment. The raced recovery inspector now returns read-only observations/action descriptors. Only the still-active caller may pass bounded rechecks and broadcast the original signed bytes. The controlled slow-read regression verifies that resolving an old timed-out read cannot newly start the payout effect.

Evidence. Fresh source call-graph review and E-01 effect-boundary/timeout tests. Exact-byte and uncertain-send ownership remain enforced.

Limits. Cancellation is not rollback of a broadcast already started, and a last-read-to-mining race is not claimed eliminated. The closure addresses the original asynchronous callback that initiated a new effect after timeout.

Smallest appropriate action. Preserve the read/effect separation and negative late-resolution tests; keep uncertain sends durable. Do not wrap effectful callbacks in a timeout race as an apparent simplification.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/gas-sponsor.mjs.

F-34 - Provisional spendable state diverges from recovered or current receipt evidence

Current: Low / OPEN. **Previous:** Low / OPEN.

Original cause / boundary. The new spendable_at marker lacks complete state transitions: crash-recovered canonical inclusion sets the marker while leaving the grant reserved with its tx_hash still NULL despite the durable prepared hash, whereas a later absent or noncanonical receipt leaves an old submitted grant marker intact. Public projection recognizes submitted+marker but cannot distinguish historical from current inclusion.

Current assessment. Recovered inclusion and provisional spendable projection are still not uniformly synchronized with durable submitted identity and later canonical evidence. A reserved row can retain incomplete transaction projection, and a provisional marker can outlive disproven inclusion.

Evidence. Fresh sponsor recovery/projection source review; E-01 relevant tests are positive controls but do not establish closure of the remaining branches.

Limits. Provisional spendability is distinct from final settlement. No duplicate payout or principal loss is asserted merely from a stale projection.

Smallest appropriate action. Persist recovered transaction identity/submitted transition atomically, and downgrade disproven provisional inclusion without deleting the underlying obligation or reassigning its nonce.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/gas-sponsor.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/managed-relay/server.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/indexer/sql/015_sponsor_spendable_receipt.sql.

Source: xgr-interchain @ 33a4e37cf48c / apps/web/transfer-actions.js.

F-35 - An out-of-scope record can indefinitely stall optional gas observation

Current: Low / PARTIALLY_MITIGATED. **Previous:** Low / OPEN.

Original cause / boundary. The delivery gas observer scans a shared Mailbox but requires every accepted-looking event in the window to have one catalog-indexed delivered operation and a known gas profile before advancing its cursor. Permanently out-of-scope events are treated like temporary evidence gaps. The onward observer likewise stops at the first unprofileable child row.

Current assessment. The onward optional gas observer now skips the addressed out-of-scope case, but the delivery observer can still hold an entire range on missing/unmatched optional data. A fix to one sampling cursor does not close both paths.

Evidence. Fresh comparison of onward and delivery observer control flow; E-01 gas observer tests cover their stated path only.

Limits. This is optional statistical sampling, separate from authenticated main transfer/debt cursors. No authorization weakening is recommended to obtain metric progress.

Smallest appropriate action. Give both optional observers bounded independent progress while retaining accepted-sample verification. Test missing profiles/unmatched operations without advancing mandatory financial cursors unsafely.

Source: xgr-interchain @ 33a4e37cf48c / services/indexer/gas-observer.mjs.

Source: xgr-interchain @ 33a4e37cf48c / contracts/XETATokenFactoryV315.sol.

Source: xgr-node @ a84c82737dc3 / interchain/runtime/iln_discovery.go.

Source: xgr-interchain @ 33a4e37cf48c / services/indexer/transfer-index.mjs.

Source: xgr-interchain @ 33a4e37cf48c / apps/web/route-availability.js.

F-36 - Creator queue lacks per-item failure isolation

Current: Medium / OPEN. **Previous:** NEW / NEW.

Original cause / boundary. An admitted, email-confirmed request can remain unprocessable by the deployment worker while occupying the first work position.

Current assessment. An independent isolated reproduction accepted and confirmed a request, then observed three blocked worker sweeps with no healthy sibling progress. A controlled positive fixture demonstrated that otherwise valid work can progress. Two validation-boundary variants share this same missing isolation cause and are counted once.

Evidence. E-07 protected Creator reproduction/result hashes; real registration and worker code with mocked RPC/mail effects. Zero real broadcasts.

Limits. No unauthorized token ownership, minting or principal theft was demonstrated. Detailed unresolved input recipes and executable fixtures are withheld from public publication. Test-fixture removal is not a production recovery instruction.

Smallest appropriate action. Reject unprocessable configurations before admission, isolate each item's bounded failure/backoff/quarantine and continue healthy work. Preserve all uncertain signed deployment identities and add negative/positive queue-progress tests.

Source: xgr-interchain @ 33a4e37cf48c / services/onboarding/creator-registration.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/onboarding/creator-operator.mjs.

Source: xgr-interchain @ 33a4e37cf48c / contracts/XITAStarterTokenCreator.sol.

F-37 - Contact retention can remove unresolved Creator deployment evidence

Current: Low / OPEN. **Previous:** NEW / NEW.

Original cause / boundary. Financial recovery identity shares a deletion lifecycle with an expiring private contact record.

Current assessment. A clock-controlled isolated test observed an unresolved deployment-submitted record, including signed recovery identity, removed when the configured long contact-retention period expired. Durable nonce/transaction recovery should not depend on retaining personal contact data indefinitely.

Evidence. E-07 protected Creator retention reproduction and source review of private storage/operator recovery.

Limits. The default long retention period is a material prerequisite. No real production record was removed, and no duplicate send or nonce reuse was demonstrated.

Smallest appropriate action. Separate contact/PII retention from immutable unresolved deployment evidence. Purge recovery state only after authenticated terminal completion and retain minimal nonpersonal identity until then.

Source: xgr-interchain @ 33a4e37cf48c / services/onboarding/private-store.mjs.

Source: xgr-interchain @ 33a4e37cf48c / services/onboarding/creator-operator.mjs.

F-38 - Creator child-token proof comparison omits canonical block identity

Current: Low / OPEN. **Previous:** NEW / NEW.

Original cause / boundary. The proof projection compared between witnesses does not retain all receipt block-identity information used by the underlying observations.

Current assessment. An independent injected-RPC test accepted two differing receipt block identities after they collapsed to the same child-token proof projection. Token address/owner/supply checks remain; the defect is narrower canonical provenance, not demonstrated token forgery. The separate factory deployment verifier has stronger block binding.

Evidence. E-07 protected witness-projection reproduction; fresh child-token versus factory verification source comparison.

Limits. No fabricated token or unauthorized owner was demonstrated. Two endpoints are still not a cryptographic light client or proof of infrastructure independence.

Smallest appropriate action. Compare chain, block height and block hash in the verified child proof and require canonical numbered-block rereads before promotion. Retain all token feature/runtime checks.

Source: xgr-interchain @ 33a4e37cf48c / services/onboarding/creator-chain-proof.mjs.

F-39 - Mintable Creator presentation retains a no-additional-minting label

Current: Informational / OPEN. **Previous:** NEW / NEW.

Original cause / boundary. A constant user-facing label is not derived from the selected validated token feature configuration.

Current assessment. A fresh rendering assertion shows the no-additional-minting label for a mintable token while the advanced fields also disclose mint permissions and the cap. The result is contradictory presentation, not an authorization bypass.

Evidence. E-07 protected presentation assertion/result hashes and current Creator UI source.

Limits. Owner/minter controls and lifetime cap tests pass. No unauthorized mint was demonstrated.

Smallest appropriate action. Derive the summary label from the validated token type and render every fixed/burnable/mintable variant in regression tests.

Source: xgr-interchain @ 33a4e37cf48c / apps/web/token-creator.js.

7. Historical reconciliation

All 35 preceding current entries are reassessed and all 43 historical occurrences are retained in historical-findings-matrix.csv. Every old column is preserved byte-for-byte at the CSV cell level; v3_3 columns append current decisions, evidence and source identities. Legacy-only resolved occurrences remain distinct from new current F-IDs. Duplicate historical reports do not add unique causes to the severity totals. The readable companion matrix provides the per-occurrence rationale.

Inherited original reproductions are not silently called fresh tests. Exact unchanged blob identities support carrying controls forward; changed integrations are reviewed on the target. Where only a source proof establishes a remaining branch, particularly F-20, that evidence type is explicit. Green package results do not override a demonstrated reachable source residual.

8. Priorities and evidence needed for closure

First repair public Creator queue isolation and validation, keeping uncertain deployment identity durable. Complete sponsorship fair/bounded read work and operator-owned paid-obligation outcomes before claiming unrestricted autonomy. Finish durable recovery handoff and native pending-principal presentation/support. Preserve the three newly verified repairs, then correct the eight test-fixture/coverage failures without weakening security assertions. Full per-finding acceptance actions are in remediation.md.

No new operator risk acceptance is inferred. Where an installed operating decision depends on missing data, obtain existing sanitized service revision, actual restricted-role checks, unresolved-liability age/outcome summaries and executable hashes before drawing an adverse host conclusion. A new paid Mainnet test, new signature, worker restart, contract redeployment or discarded debt is not required merely to improve the report's appearance.

9. Limitations, disclosure and conclusion

This review combines fresh finite execution, manual source reasoning, inherited evidence and scoped read-only observations. It is not formal verification, an exhaustive fuzzer campaign, a full third-party infrastructure audit or a guarantee of secure deployment. No production state database, private validator key or full host inventory was accessed. Public third-party reproducibility of the new unresolved cases is intentionally limited by responsible disclosure; the operator receives protected identities separately.

The evidence supports genuine improvement without a clean-bill-of-health shortcut: three original causes are closed, one is downgraded, several partial fixes retain narrower residuals, and the newly expanded Creator surface contributes four distinct causes. Core token authorization/backing controls and the targeted v3.5.0 possession repair have positive evidence. Autonomous service availability and complete paid-obligation handling still require the stated corrective work and operating decisions.

Appendix A. Evidence references

Read verification.md for E-01 through E-07, exact execution runs, environments and limits. evidence-public.zip and archive-manifest.json bind the actual public evidence bytes. Public source URLs and exact target/blob identities for every finding are in finding-details.json and evidence/current-source-comparison.json. Existing historical audit directories remain unchanged.